



Klints · Klints Confidential

MVP1 Security, Privacy & AI Compliance Execution Blueprint

Working implementation guide for Astrapse Labs. Derived from the v1.3 Review Draft; the full blueprint remains the authoritative control and evidence baseline.

Prepared by: Comenius Agency s.r.o. · Date: 10 August 2026 · Version: v1.0 · Working Edition

Stack integrity, orchestrated.

Product	Owner and contracting entity	Development partner
Klints MVP1	Comenius Agency s.r.o.	Astrapse Labs
Status — Working Edition · Execution guide. Does not replace, approve or amend the v1.3 full blueprint.		
Version v1.0	Date 10 August 2026	Classification Klints Confidential

1 Quick Start

CURRENT DECISION

CONDITIONAL GO. Synthetic development may proceed now. Live tenant data remains blocked until Gate B is complete and evidenced. Write-capable connectors and MCP execution remain blocked until Gate C.

This document is the short operational companion to Klints_MVP1_Security_Privacy_AI_Compliance_Blueprint_v1.3_20260807. It is designed for day-to-day implementation, estimation and evidence tracking. It does not replace, approve or amend the full blueprint. If the two documents differ, v1.3 prevails and the conflict must be raised before implementation.

1.1 What Rohan should do first

- **Confirm the baseline.** Return a marked response identifying accepted requirements, technical conflicts, proposed alternatives and decisions needed from Comenius.
- **Confirm the implementation route.** Identify the DigitalOcean product, GitHub plan and repository visibility, secrets/key-management approach and the intended deployment flow.
- **Return an estimate.** Provide a bottom-up estimate by work package, including dependencies, critical path, external blockers and evidence work.
- **Build with synthetic data.** Do not wait for Gate B legal and provider evidence where implementation can proceed safely with synthetic fixtures and stubbed services.
- **Produce evidence while building.** A control is not complete because code exists. Its evidence and acceptance result must be retained with the relevant requirement ID.

1.2 Status at a glance

Gate	Purpose	Current status	What this means now
A	Synthetic development	OPEN	Engineering may proceed using synthetic data and non-production credentials only.
B	First live read-only tenant	BLOCKED	No live tenant data until all Gate B items are complete and evidenced.
C	Write connector or MCP	BLOCKED	No tenant-system write path in the current live phase.
D	First paying or public launch	FUTURE GATE	Commercial launch requirements remain cumulative with Gate B.
E	Cross-tenant benchmarks	POST-MVP	Only tenant-local outcome instrumentation is built in MVP1.

1.3 Working rule

NO SILENT ASSUMPTIONS

An open item must never be resolved informally in code. Record it as Accepted, Alternative proposed, Comenius decision required, Legal/provider evidence required, or Not applicable with reason.

2 Locked MVP1 Direction

The following decisions are treated as fixed for estimation and implementation unless Comenius Agency formally changes the v1.3 baseline.

- **Deployment model.** Shared multi-tenant service with strong logical isolation is the MVP1 default. A dedicated single-tenant deployment is not the baseline.
- **Hosting intent.** DigitalOcean Frankfurt is the intended primary region. The exact DigitalOcean product and service map remain open and must be decided.
- **AI route.** One direct Mistral EU route using pinned model identifier mistral-small-2603. No OpenRouter, no automatic Scaleway fallback and no floating model alias.
- **AI fallback.** A complete deterministic Klints report template is the only MVP1 fallback when the provider is unavailable or an AI response is rejected.
- **Model egress.** The AI Data Contract is allow-list based, fails closed on unknown fields and applies cohort and suppression rules. The provisional platform minimum is 50 distinct data subjects.
- **Tenant access.** The first live phase is read-only. Write scopes and executable MCP tools are not activated before Gate C.
- **Reports.** The canonical structured payload is authoritative. The PDF is generated for delivery, hashed at issue and is not permanently stored by default.
- **Outcome data.** MVP1 records tenant-local issue, fix and outcome events. There is no cross-tenant contribution, aggregation or benchmark publication plane.

2.1 Explicitly deferred

- Write-capable connectors and executable MCP workflows.
- A second external AI provider.
- Cross-tenant benchmark computation and publication.
- Dedicated single-tenant or customer-hosted deployment as the default product.
- SSO and other enterprise identity extensions not required for the first MVP1 live gate.

SCOPE CONTROL

Deferred features must not create dormant production paths, unused write credentials or hidden cross-tenant data flows. If scaffolding is retained, it must remain unreachable and excluded from live configuration.

3 Critical Path and Next Best Steps

Gate B closes only when three parallel lanes converge. Engineering is one lane, not the whole programme.

Lane	Immediate owner	Outputs required before Gate B
A Product, legal and contracts	Comenius + counsel	Processing and transfer instruments; report-audience and Article 50 decisions; retention; legal roles; design-partner jurisdiction; named owners.
B Architecture and implementation	Rohan / Astrapse Labs	As-built architecture; secure platform; test results; runbooks; deployment evidence; bottom-up estimate and critical path.
C Provider and independent evidence	Comenius + providers + reviewer	Mistral evidence; DigitalOcean service map; GitHub capability facts; independent isolation and credential-store reviews.

3.1 Recommended sequence

Step 1 Baseline response. Rohan returns the requirement disposition, architecture questions and bottom-up estimate. Comenius resolves the decisions that prevent design finalisation.

Step 2 Platform foundation. Fix deployment product, environments, network boundaries, database roles, secrets architecture and CI/CD constraints.

Step 3 Highest-risk controls. Implement tenant isolation and connector credential protection first. These are the controls most capable of invalidating the shared architecture.

Step 4 AI and report path. Implement the AI Data Contract, Mistral EU route, validation/fallback, canonical report payload, report access and provenance.

Step 5 Operational readiness. Complete logs, monitoring, backup restore, deletion replay, incident response, access control, deployment approval and secondary-operator runbooks.

Step 6 Independent evidence and Gate B review. Run the acceptance catalogue, obtain independent review, disposition findings and assemble the customer security evidence pack.

3.2 What may run in parallel

- Astrapse processing/transfer documentation, Mistral evidence and DigitalOcean service mapping should start immediately because they have external lead time.
- Rohan may implement synthetic-data controls while those external items are pending, provided no live data or live credential enters the environment.
- Article 50 and retention decisions may be pending while the report pipeline is built to support either approved outcome without re-architecture.
- The independent reviewer should be selected before isolation and credential-store implementation finishes, so evidence expectations are agreed before review.

4 Ownership and Immediate Handoff

4.1 Responsibility split

Party	Accountable for now	Must not decide alone
Rohan / Astrapse Labs	Architecture options; implementation; automated tests; as-built evidence; runbooks; estimate and dependencies.	Legal roles; product audience; retention periods; acceptance of residual risk; authorisation of live data.
Comenius Agency	Product decisions; accounts; owner appointments; acceptance of risk; approval of gates; customer-facing claims.	Technical feasibility or security evidence without Rohan and the independent reviewer.
Counsel / privacy owner	Processing roles; transfers; Article 50 determination; DPIA screening; contract language.	Engineering architecture or undocumented product-intent assumptions.
Independent reviewer	Independent review of tenant isolation and credential handling; findings and dispositions.	Implementation ownership or self-review of code they authored.
Providers	Contractual and service evidence for Mistral, DigitalOcean and GitHub capabilities.	Klints compliance claims or Gate B approval.

4.2 First response required from Rohan

- **Disposition matrix.** For every requirement referenced by the work packages: Accepted; Alternative proposed; Comenius decision required; Legal/provider evidence required; or Not applicable with reason.
- **Architecture pack.** Current and target diagrams, complete service/region inventory, ingress/egress paths, data stores, secrets and key hierarchy, access paths, logging, monitoring and backups.
- **Decision recommendations.** Preferred DigitalOcean product, database topology, secrets/key-management product and GitHub protection mechanism, with trade-offs.
- **Estimate.** Bottom-up effort by work package, named dependencies, external blockers, critical path and the point at which independent review should occur.
- **Deviation list.** Any conflict with the current codebase or any control that would materially change cost, schedule or the product architecture.
- **Evidence plan.** Where each test result, configuration export, review record and runbook will be stored and who will produce it.

IMPORTANT

A requirement should be challenged before build if it is technically unsound. It should not be reinterpreted silently to fit the existing implementation.

5 Engineering Work Packages

The work packages below are the day-to-day build structure. Full normative wording and tests remain in v1.3. Status should be tracked as Not started, In progress, Evidence pending, Blocked, Ready for independent review, or Complete.

WP0 Baseline, Architecture and Estimate

Outcome. A reviewed and estimable build baseline with no hidden disagreement between the current system and v1.3.

Rohan / Astrapse Labs actions

- Return the marked requirement disposition and identify every technical conflict or assumption.
- Produce current-state and target-state architecture and data-flow diagrams.
- Provide the complete infrastructure, service, region, account and external-endpoint inventory.
- Provide a bottom-up estimate by WP1 to WP8, dependencies, critical path and external lead-time assumptions.

Inputs or decisions from Comenius. O-01, O-02, O-03 and initial answers on O-13 must be resolved jointly; Comenius supplies account and repository facts.

Evidence to retain. Disposition matrix; diagram pack; inventory; estimate; dependency map; deviation register.

Done when. Comenius and Rohan agree the implementation route and all material deviations are recorded for decision.

Authoritative references. Sections 2.3, 3.4, 23.2 and 36.2; O-01 to O-03; GB-17 and GB-18.

WP1 Hosting, Environments and Network Boundaries

Outcome. A reproducible DigitalOcean Frankfurt deployment with documented service geography, controlled ingress/egress and separated environments.

Rohan / Astrapse Labs actions

- Recommend and document the exact DigitalOcean deployment product and managed services used.
- Define development, staging and production boundaries; production data and credentials must not exist outside production.
- Hard-code approved external destinations and deny user-, tenant- or data-controlled provider endpoints.
- Document support, administrative and break-glass paths, including access expiry and audit events.
- Produce an as-built service/region map and identify facts that remain provider claims or not established.

Inputs or decisions from Comenius. Comenius confirms account ownership and decides the deployment product after Rohan's recommendation; DigitalOcean supplies service-level evidence.

Evidence to retain. Infrastructure definitions; network diagram; egress configuration; environment inventory; account ownership evidence; service/region map.

Done when. Synthetic deployment is reproducible; no production secret exists outside production; unapproved egress is blocked and logged.

Authoritative references. Sections 3.4, 5.4, 10.4-10.5 and 23; GA-01 to GA-04; GB-16 to GB-18; AI-06.

WP2 Tenant Isolation, Identity and Production Access

Outcome. Tenant A cannot access any Tenant B object through HTTP, database, pooler, background jobs, scheduled jobs, reports, support tooling, credentials or AI metadata.

Rohan / Astrapse Labs actions

- Implement tenant identifiers on all tenant-controlled records and enumerate read-only global tables.
- Enforce PostgreSQL RLS with FORCE ROW LEVEL SECURITY; application roles must not own tenant tables or hold BYPASSRLS.
- Use transaction-scoped tenant context and test connection-pool leakage and missing-context failure.
- Validate tenant membership server-side for every request and job; JWT claims are not the trust boundary.
- Define least-privilege roles, privileged MFA, session revocation, support role and break-glass access.
- Run the complete TEN negative-test family in CI and prepare the implementation for independent review.

Inputs or decisions from Comenius. Comenius supplies named support/admin holders, approves the revocation target and selects the independent reviewer.

Evidence to retain. Schema and role queries; RLS policies; pooler configuration; TEN test output; access matrix; break-glass test; independent review record.

Done when. TEN-01 to TEN-09 pass; no unresolved Critical or High finding; Medium and Low findings meet the v1.3 disposition standard.

Authoritative references. Sections 11-12 and 24; GB-13 and GB-15; TEN-01 to TEN-12; IAM-01 to IAM-10.

WP3 Connector Credentials and Read-Only Ingestion

Outcome. Database compromise or restoration outside the approved trust boundary does not yield usable tenant connector credentials.

Rohan / Astrapse Labs actions

- Recommend the key/secrets product once WP1 fixes the deployment product.

- Keep the key-encryption key outside the application database and use per-tenant or finer data-encryption keys.
- Implement rotation, emergency rotation, revocation and auditable credential reads.
- Prove one tenant key cannot decrypt another tenant's credential and restored development backups cannot decrypt credentials.
- Define a read-only scope matrix and field allow-list for every connector; do not request write scopes.
- Treat all ingested tenant content as untrusted data, never as instructions.

Inputs or decisions from Comenius. Comenius approves the selected key-management route and provides tenant permission wording; connector providers supply exact scope definitions.

Evidence to retain. Key hierarchy; access policy; scope matrix; field allow-lists; rotation/revocation procedures; CON tests; independent review record.

Done when. CON-01 to CON-06 pass, credential handling is independently reviewed and production read scopes are the minimum required.

Authoritative references. Section 13 and 24; O-13; GB-14; CON-01 to CON-16.

WP4 AI Gateway, Data Contract and Mistral Route

Outcome. Only approved, policy-compliant AI payloads reach the pinned Mistral EU endpoint; every rejection uses the internal deterministic template.

Rohan / Astrapse Labs actions

- Implement a server-side Klints AI gateway with a hard-coded EU endpoint, pinned mistral-small-2603 and returned-model verification.
- Implement the allow-listed AI Data Contract, unknown-field fail-closed behaviour, canary corpus, redaction manifest, policy version/hash and input digest.
- Apply the provisional minimum of 50 distinct data subjects, rare-value suppression, dimensionality limits and tenant commercial-data flag defaulted off.
- Prevent prompts and responses from entering logs, traces, telemetry or error reporting.
- Reject malformed, ungrounded, unknown-ID, numeric-fabrication and substituted-model responses; never stream unvalidated output.
- Implement and test a complete deterministic fallback with Mistral unreachable.

Inputs or decisions from Comenius. Comenius creates the Mistral organisation account, provides MPA evidence, decides O-25 and obtains required legal/provider evidence.

Evidence to retain. Configuration export; policy schema; canary output; manifests; log scan; adversarial corpus; AI-01 to AI-11 results; fallback sample.

Done when. Group 1 Mistral preconditions are complete; AI Data Contract tests pass; global endpoint and unknown destinations are unreachable; fallback report is complete.

Authoritative references. Sections 14-18; GB-08 to GB-12; ADC-01 to ADC-18; MPA-01 to MPA-12; AI-01 to AI-11.

WP5 Assessment Report, Access and Provenance

Outcome. Every issued report is tenant-scoped, traceable to an immutable canonical payload and auditable without relying on byte-identical regeneration.

Rohan / Astrapse Labs actions

- Implement the canonical payload fields and make the issued payload immutable; corrections create a superseding report.
- Compute and store the canonical payload hash and issued-PDF SHA-256 before the ephemeral PDF is discarded.
- Render regeneration from stored narrative, never by re-running the model, and test semantic consistency.
- Implement authenticated or explicitly accepted short-lived delivery, unguessable report identifiers and access audit records.
- Carry document-level provenance through validation, human editing, composition and PDF rendering.
- Keep cryptographic signing optional until Comenius decides O-26; do not block the base hash/provenance work.

Inputs or decisions from Comenius. Comenius decides the report audience, O-26 signing status and retention treatment; counsel completes the Article 50 determination.

Evidence to retain. Canonical schema; payload and artefact hashes; access transcript; audit sample; semantic re-render result; provenance inspection record.

Done when. REP-01, REP-02, REP-04 and REP-05 pass; report access is tenant-scoped; provenance survives into the issued artefact.

Authoritative references. Sections 12.2, 19-20 and 35.5; O-09, O-10, O-26 and O-28; GB-05, GB-22 and GB-23.

WP6 Logging, Retention, Backups and Incident Readiness

Outcome. Klints can reconstruct security-relevant actions, expire and delete approved data, restore safely and execute a named incident response.

Rohan / Astrapse Labs actions

- Define append-only audit events for access, credentials, reports, AI metadata, deployments and administrative actions without logging prohibited content.
- Implement the retention matrix as configuration after approval; do not hard-code an invented default.
- Implement expiry, deletion records, backup expiry and deletion replay after restore.
- Define monitoring for isolation failures, credential access, authentication abuse, egress failures and provider or deployment anomalies.
- Write incident, credential-compromise and cross-tenant-exposure runbooks and support a tabletop exercise.

- Implement and time a clean-environment restore and document degraded operation when the model, a connector or renderer is unavailable.

Inputs or decisions from Comenius. Comenius approves retention/legal hold, RTO/RPO, incident owners, contacts and escalation targets.

Evidence to retain. Audit samples; retention configuration; deletion and restore transcripts; alert test fires; runbooks; tabletop and degraded-mode records.

Done when. RET-01 to RET-04, IR-01 and BCP-02 pass; five required alert classes fire; named responders can execute the runbook.

Authoritative references. Sections 21-22 and 25-26; O-11, O-12, O-18 and O-19; GB-07 and GB-19 to GB-21.

WP7 Secure CI/CD, Review and Continuity

Outcome. The production artefact is reviewed, immutable, reproducible from the pipeline and deployable or recoverable by someone other than its author.

Rohan / Astrapse Labs actions

- Establish repository visibility, organisation plan and the independent production approval mechanism.
- Separate production credentials; restrict them to the production job and narrowest supported scopes.
- Protect the default branch; pin actions to commit hashes; run dependency, container and secret scans; retain the SBOM.
- Build once and promote the same digest; separate migration credentials and approvals; test a documented rollback action.
- Record digest, approver, migration status, timestamp and outcome for every deployment.
- Write deployment, patch, restore and credential-rotation runbooks and demonstrate deployment by a second person.

Inputs or decisions from Comenius. Comenius confirms GitHub facts, names the independent approver and identifies the secondary operator.

Evidence to retain. Workflow configuration; branch/environment protection; token scopes; scan/SBOM output; digest trace; rollback test; second-person deployment record.

Done when. CICD-01 to CICD-05 pass; the author cannot deploy alone; production secrets are inaccessible from ordinary builds and forks.

Authoritative references. Sections 23, 24 and 26; O-02, O-03 and O-14; GB-18; CICD-01 to CICD-13; BCP-03 and BCP-07.

WP8 Tenant-Local Outcome Instrumentation

Outcome. MVP1 records issue-to-fix-to-outcome sequences inside each tenant without creating any cross-tenant contribution or benchmark path.

Rohan / Astrapse Labs actions

- Implement tenant-scoped issue, proposed-fix, approved-fix, execution-status and outcome-observation events.
- Record attribution windows, method/version, observation confidence and metric provenance.
- Ensure the subsystem has no contribution plane, no cross-tenant aggregation and no external benchmark egress.
- Include the outcome objects in tenant-isolation tests, retention treatment and access logging.

Inputs or decisions from Comenius. Comenius confirms the MVP1 outcome vocabulary and product-facing labels; benchmark programme decisions remain outside this work package.

Evidence to retain. Schema; sample tenant-local event chain; data-flow inspection; BEN-01 test; isolation and retention evidence.

Done when. BEN-01 passes and the architecture contains no active cross-tenant benchmark path.

Authoritative references. Section 28; GB-24; BEN-01. Gate E controls are future and are not implemented here.

6 Gate B Readiness Checklist

GATE RULE

Gate B is cumulative and binary. No live tenant data is authorised until every blocker is complete, evidenced and approved by Comenius Agency. A working feature without evidence remains incomplete.

6.1 Contractual, product and legal

ID	Required outcome	Primary owner	Current baseline
GB-01	Astrapse Labs Article 28 terms, SCCs where required and TIA executed or confirmed.	Comenius + counsel	Not established
GB-02	Tenant agreement and Article 28/subprocessor terms ready and signed before ingestion.	Comenius + counsel	Planned
GB-03	Mistral DPA executed and subprocessor position obtained.	Comenius	Not established
GB-04	Subprocessor register and ROPA complete, dated and available.	Comenius	Planned
GB-05	Report audience decision and Article 50 legal determination held before external pilot.	Comenius + counsel	Not established
GB-06	DPIA screening signed; full DPIA completed if screening establishes likely high risk.	Comenius + joint	Planned
GB-07	Retention matrix covering all five artefacts, logs, audit and backups approved.	Comenius	Planned

6.2 AI route and egress

ID	Required outcome	Primary owner	Current baseline
GB-08	Mistral evidence handled under the four-group model; Group 1 cannot be dispositioned.	Comenius	Not established
GB-09	AI Data Contract, allow-list, suppression, manifest and fail-closed behaviour implemented.	Comenius + Astrapse	Planned
GB-10	EU region pinned; start-up fails if region is absent; global endpoint cannot be selected.	Comenius + Astrapse	Planned
GB-11	No prompt or response content in logs, traces, telemetry or error reporting.	Comenius + Astrapse	Planned
GB-12	Complete report produced through deterministic fallback with provider unreachable.	Comenius + Astrapse	Planned

6.3 Isolation, credentials and access

ID	Required outcome	Primary owner	Current baseline
GB-13	Tenant isolation implemented, all negative tests passed and independently reviewed.	Astrapse + reviewer	Planned
GB-14	Credential store implemented, backup-decryption test passed and independently reviewed.	Astrapse + reviewer	Planned
GB-15	No standing production access; named access matrix and expiring break-glass tested and audited.	Comenius + Astrapse	Planned
GB-16	DigitalOcean and production account ownership documented under Comenius Agency.	Comenius	Planned

6.4 Operations and evidence

ID	Required outcome	Primary owner	Current baseline
GB-17	Service-by-service hosting map complete; every unavailable fact recorded, not converted into a claim.	Comenius + Astrapse	In progress
GB-18	Independent production deployment approval and CI/CD capability facts evidenced.	Comenius + Astrapse	Conditional
GB-19	Clean restore and deletion replay tested; deleted records absent before restored environment is exposed.	Comenius + Astrapse	Planned
GB-20	Incident runbook complete and one tabletop exercise performed.	Comenius + joint	Planned
GB-21	Security monitoring live and all five alert classes test successfully.	Comenius + Astrapse	Planned
GB-22	Canonical payload, both hashes, semantic re-render and issuance/access audit implemented.	Comenius + Astrapse	Planned
GB-23	Article 50-ready document provenance survives the full report pipeline.	Comenius + Astrapse	Planned
GB-24	Tenant-local outcome instrumentation active with no contribution plane.	Comenius + Astrapse	Planned
GB-25	Versioned customer security evidence pack assembled; every answer has an evidence reference.	Comenius	Planned

7 Minimum Acceptance Evidence

Use the full procedures in Section 35 of v1.3. The matrix below is the minimum execution index, not a replacement test specification.

Family	What must be demonstrated	Evidence retained	Gate
TEN-01 to TEN-09	No cross-tenant access through every defined access path, including DB role, pooler, jobs, reports, support, credentials and AI metadata.	CI output, query transcripts, review record	B
IAM	Server-validated identity, tenant membership, privileged MFA, revocation, offboarding and audited break-glass.	Configuration, timing tests, access/audit samples	B
CON-01 to CON-06	One tenant key cannot decrypt another; revoked tokens fail; logs are clean; restored development backup cannot decrypt credentials.	Test output, log scan, restore transcript	B
AI-01 to AI-11	Prohibited data blocked; unknown fields fail closed; regional endpoint enforced; invalid output rejected; fallback complete; substitution detected.	Canary and adversarial runs, manifests, log scan	B
REP-01 to REP-05	Report access is scoped; issued hash matches; values trace to payload; semantic re-render passes; provenance survives.	HTTP transcript, hashes, comparison and inspection records	B
RET-01 to RET-04	Expiry, erasure, restore/deletion replay and backup expiry follow the approved policy.	Job logs, store inspection, restore transcript	B
CICD-01 to CICD-05	Author cannot deploy alone; secrets unavailable to branch/fork; same reviewed digest promoted; rollback works; logs contain no tenant data or secret.	Pipeline transcripts, digest trace, timed rollback, scans	B
IR-01 / BCP-02	Named responder can execute the incident runbook; clean restore meets approved objectives.	Tabletop record, timed restore	B
BEN-01	No cross-tenant contribution, aggregation or egress exists in MVP1 outcome instrumentation.	Architecture inspection and egress log	B

7.1 Review finding standard

SINGLE STANDARD

No unresolved Critical or High finding. Every Medium finding must be closed, assigned a documented treatment plan with owner and deadline, or formally accepted by the accountable owner. Every Low finding must be recorded and tracked. A formal acceptance of a Medium finding belongs in the Decision and Exception Register.

7.2 Evidence naming and storage

- Use the authoritative ID at the start of every evidence filename, for example TEN-03_pooler_isolation.pdf.
- Store raw test output and a short human-readable result summary. Screenshots alone are not sufficient where machine output exists.

- Record environment, artefact/commit digest, tester, date, result and linked finding or exception.
- Redact secrets and tenant data from evidence. Live design-partner data must not be copied into the evidence repository.
- Keep failed results and their remediation history; do not retain only the final passing screenshot.

8 Gate B Blocking Decisions and Evidence

These items require owner action outside normal implementation. Rohan should identify dependencies and recommendations, but must not select product, legal or risk outcomes on behalf of Comenius Agency.

8.1 Immediate Comenius decisions

ID	Decision	Input required from Rohan	Owner
O-01	Exact DigitalOcean product	Recommended option, trade-offs, deployment and credential implications	Comenius + Astrapse
O-02/O-03	GitHub plan, visibility and independent approver	Required protection mechanism and feasible fallback	Comenius
O-09	Assessment Report intended audience	Confirm how access and download controls support each option	Comenius
O-11/O-12	Retention periods and legal-hold policy	Inventory of stores, logs, backups and deletion capabilities	Comenius
O-13	Key/secrets implementation	Preferred technical option after O-01	Astrapse
O-16/O-17	First design partner, jurisdiction and scale	Capacity/security constraints and maximum supported volumes	Comenius
O-18	RTO and RPO	Feasible targets and cost/architecture consequences	Comenius
O-19	Incident owners and contact routes	Runbook roles and technical escalation needs	Comenius
O-25	Exact sanitised A1 payload retention	Implementability, storage and deletion implications of Options A/B	Comenius + privacy
O-26	Cryptographic signing at P0 or enhanced control	Implementation cost and key-custody implications	Comenius
O-27	Session revocation service level	Measured feasible target and technical dependency	Comenius

8.2 Legal and contractual determinations

- O-04: Astrapse Labs Article 28 terms, SCCs where required and transfer impact assessment.
- O-10 and O-28: Article 50 applicability, first external pilot status and any transition or R&D analysis.
- O-23: NIS2 and Czech Act No. 264/2025 Coll. screening inputs and decision D-17.
- O-24: Controller, processor or subprocessor position for the tenant relationship.
- O-29: Mistral GDPR role after the production payload, telemetry and terms are assessed.

8.3 External provider evidence

Source	Required now	Rohan's role
Mistral	MPA-01 to MPA-07 mandatory; MPA-08, 09 and 11 evidenced or formally dispositioned; MPA-10 requested/status recorded; MPA-12 cost planning only.	Implement technical tests and supply exact endpoint/model/configuration evidence.
DigitalOcean	Service-by-service region, subprocessor, support, backup, deletion, logging and disaster-recovery map plus DPA.	Supply exact service inventory and identify documentation gaps.
GitHub	Plan, visibility and available production deployment protection for that combination.	Supply workflow design and required capability facts.
Independent reviewer	Isolation and credential-store review by someone other than the code author.	Prepare reviewable evidence and resolve findings.

9 Working Method and Control of Change

9.1 Suggested implementation board

Field	Required content
Requirement ID	Full blueprint ID or work-package ID.
Status	Not started; In progress; Evidence pending; Blocked; Ready for independent review; Complete.
Owner	Named individual, not only an organisation.
Dependency	Open decision, provider evidence, another WP or external reviewer.
Implementation reference	Ticket, pull request, commit and deployed artefact digest.
Evidence	Test result, configuration export, review record, runbook or executed instrument.
Exception	Decision Register entry, owner, expiry/review date and residual risk.

9.2 Review cadence

- **Implementation review.** Review work-package status, new dependencies and architecture deviations at least weekly while Gate B work is active.
- **Evidence review.** Do not wait until the end. Review evidence as each control reaches Ready for independent review.
- **Decision review.** Escalate any item that blocks final architecture, creates material cost or schedule impact, or would change a customer-facing security claim.

- **Gate review.** Gate B closes only through an explicit Comenius approval based on the complete evidence register.

9.3 Change and exception protocol

When the current implementation cannot meet a requirement, Rohan should submit a short change note containing:

- the affected requirement and work package;
- the technical reason and evidence;
- the proposed alternative;
- security, privacy, product, cost and schedule impact;
- the residual risk and compensating controls;
- the decision owner and date required.

STOP CONDITION

Do not implement a material alternative until Comenius records the decision. A code merge is not approval of a security exception.

10 Gate B Handover Package

Rohan's Gate B handover should be a compact evidence pack. It does not need to repeat the full blueprint.

10.1 Required handover contents

Package	Minimum contents
Architecture	Final as-built system/data-flow diagram, service and region inventory, ingress/egress design and environment boundaries.
Isolation	Database roles and RLS evidence, pooler behaviour and full TEN negative-test output.
Credentials	Key hierarchy, access policy, connector scopes, restore-decryption test and independent review.
AI route	Redacted Mistral configuration, AI Data Contract schema, manifests, egress/log tests and deterministic fallback output.
Reports	Canonical schema, hash records, report access tests, semantic re-render and provenance inspection.
Operations	Logging/monitoring configuration, alert tests, retention/deletion implementation, restore transcript, incident and degraded-mode runbooks.
Delivery	CI/CD configuration, approval evidence, scan/SBOM outputs, digest promotion and rollback result.
Continuity	Patch process, deployment/restore runbooks and second-person deployment demonstration.
Status	Final requirement disposition, open findings, exceptions, dependencies and bottom-up estimate actuals/variance.

10.2 Final questions before Gate B

- Can Rohan demonstrate that no live data or production credential entered non-production?
- Can an independent reviewer reproduce the tenant-isolation and credential-store evidence?
- Can Klints identify exactly what left the environment in every model call without exposing prohibited content in logs?
- Can a report be traced to its canonical payload, model route, policy version, human edits and issued-file hash?
- Can a second person deploy, restore and initiate incident response using the written runbooks?
- Does every customer-facing security statement have an evidence reference or an explicit not-established qualification?

GATE B OUTCOME

If any answer is no, live tenant processing remains blocked. Synthetic development may continue unless the issue also invalidates the synthetic environment boundary.

Appendix A Where to Look in the Full Blueprint

Use this map only when implementation requires the exact normative wording, test procedure, legal analysis or evidence rule.

Working topic	Authoritative v1.3 sections	Key IDs
Scope, hosting and legal roles	Sections 2-10	O-01, O-04, O-16, O-23, O-24
Tenant isolation and identity	Sections 11-12, 24, 35.1-35.2	TEN, IAM, GB-13, GB-15
Connector credentials	Sections 13, 24, 35.3	CON, O-13, GB-14
AI gateway and provider	Sections 14-18, 35.4	ADC, MPA, AI, GB-08 to GB-12
Assessment Report and Article 50	Sections 19-20, 35.5	REP, A50, O-09, O-10, O-26, O-28
Logs, retention and privacy operations	Sections 21-22, 35.6	LOG, RET, O-11, O-12, O-25
CI/CD, testing and incidents	Sections 23-26, 35.7 and 35.9	CICD, VUL, IR, BCP
Write connectors and MCP	Section 27, Gate C, 35.8	MCP, GC-01 to GC-10
Outcome instrumentation and benchmarks	Section 28, Gate E, 35.9	BEN, GB-24, GE-01 to GE-08
Gates, risks, decisions and evidence	Sections 31-36	GA, GB, GC, GD, GE, O, D, R

Appendix B Scope Boundary for This Working Edition

This working edition intentionally omits:

- full regulatory and legal reasoning;
- the complete five-artefact classification matrix;
- the detailed threat and risk registers;
- the full RACI and acceptance-test procedures;
- detailed explanations of deterministic DCS and narrative grounding;
- future Gate C and Gate E implementation specifications.

Those omissions reduce reading time; they do not remove the underlying requirements. The authoritative content remains in v1.3.

FINAL WORKING INSTRUCTION

Use this document to organise the build. Use v1.3 to resolve exact wording, run the acceptance test and support any external security claim.